

Security+ 2.4 · DNS Attacks

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.4 — DNS Attacks (8:57)** · [Vídeo no YouTube ↗](#)

Resumo da Aula: DNS (o listado telefônico da rede): DNS spoofing/cache poisoning (resposta FALSA guardada em cache do resolver); Domain hijacking (rouba domínio no registrador); URL hijacking/typosquatting (registrar 'goggle.com'); DNS tunneling (esconde dado nas consultas DNS — exfiltra). Defesa: DNSSEC (assina registro), monitora domínio parecido, filtro DNS.

Highlights que a prova cobra

- DNS spoofing/cache poisoning: resposta FALSA guardada em cache
- Typosquatting: registra domínio com typo (rn/m, 0/o) — phishing
- DNS tunneling: exfiltra dado escondido em queries DNS

Dicas de prova & Cenários Típicos

- 'fake DNS response directs user to attacker server' = DNS spoofing/poisoning
- 'registers domain similar to legitimate one' = typosquatting

Cenário clássico de exame: Cenário: 'usuário digita domínio errado e cai em site de phishing' = typosquatting/URL hijacking.

 **Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e**

Armadilhas da Seção 2.4)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (DNS Attacks) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Atores de Ameaça (Threat Actors): Nation-state / APT (Advanced Persistent Threat):** altamente financiado, sofisticado, motivado por espionagem geopolítica a longo prazo. **Cybercriminal:** motivado por lucro financeiro direto (ransomware, extorsão). **Hacktivist:** motivado por causas políticas ou ideológicas. **Insider Threat:** funcionário ou terceiro com acesso legítimo que abusa de privilégios por dolo ou negligência.
- **Engenharia Social e Variantes de Phishing:** **Phishing:** campanha em massa por e-mail. **Spear Phishing:** ataque direcionado a indivíduo ou empresa específica usando dados de OSINT. **Whaling:** direcionado a executivos do C-level (CEO, CFO). **Vishing:** phishing por voz/telefone. **Smishing:** phishing por SMS. **BEC (Business Email Compromise):** impersonação de diretoria para desvio de faturas ou transferências bancárias.
- **Tipos de Malware e Vetores de Ataque:**
 - *Ransomware:* cifra dados corporativos e exige resgate em criptomoeda.
 - *Trojan:* software aparentemente inofensivo que instala backdoors ocultos.
 - *Rootkit:* modifica o kernel do sistema operacional e se oculta de ferramentas antivírus comuns.
 - *Worm:* malware autorreplicável que se propaga sozinho pela rede sem intervenção humana.
- **Vulnerabilidades de Aplicação (OWASP Top 10):**
 - *SQL Injection (SQLi):* manipulação de queries de banco de dados por falta de sanitização/parametrização (prepared statements).
 - *XSS (Cross-Site Scripting):* injeção de scripts maliciosos (JavaScript) no navegador da vítima.
 - *CSRF (Cross-Site Request Forgery):* induz a vítima logada a executar ações indesejadas em uma aplicação web confiável.

⚠ **Armadilhas e Pegadinhas Clássicas da Banca:**

- Phishing não é mitigado apenas por filtros de e-mail; o controle humano fundamental é a simulação periódica de phishing e conscientização.
- Rootkits operam no nível de anel de privilégio (Ring 0 / Kernel), exigindo verificação de Secure Boot (TPM) para prevenção confiável.

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Um atacante usa RFID para clonar crachás de funcionários e acessar áreas restritas.

Que tipo de ataque físico é esse?

- A)** Tailgating
- B)** Shoulder surfing
- C)** Clonagem de credenciais
- D)** Dumpster diving

2. Cenário corporativo (DNS Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'DNS spoofing/cache poisoning: resposta FALSA guardada em cache'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: DNS spoofing/cache poisoning: resposta FALSA guardada em cache...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (DNS Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Typosquatting: registra domínio com typo (rn/m, 0/o) — phishing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Typosquatting: registra domínio com typo (rn/m, 0/o) — phishing...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (DNS Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'DNS tunneling: exfiltra dado escondido em queries DNS'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: DNS tunneling: exfiltra dado escondido em queries DNS...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (DNS Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'fake DNS response directs user to attacker server' = DNS spoofing/poisoning'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'fake DNS response directs user to attacker server' = DNS spoofing/poisonin...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (DNS Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'registers domain similar to legitimate one' = typosquatting'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'registers domain similar to legitimate one' = typosquatting...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (DNS Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'usuário digita domínio errado e cai em site de phishing' = typosquatting/URL hijacking.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Cenário: 'usuário digita domínio errado e cai em site de phishing' = typosq...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (DNS Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'DNS spoofing/cache poisoning: resposta FALSA guardada em cache'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: DNS spoofing/cache poisoning: resposta FALSA guardada em cache...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (DNS Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Typosquatting: registra domínio com typo (rn/m, 0/o) — phishing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Typosquatting: registra domínio com typo (rn/m, 0/o) — phishing...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (DNS Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'DNS tunneling: exfiltra dado escondido em queries DNS'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: DNS tunneling: exfiltra dado escondido em queries DNS...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) C — Clonagem de credenciais.

✓ **Por que está certa:** Clonagem de credenciais RFIDs permite criar cópias não autorizadas de crachás/cartões de acesso, permitindo entrada física não autorizada em instalações.

✗ **Por que as outras estão erradas:**

- *Tailgating:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Shoulder surfing:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Dumpster diving:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) B — Implementar a solução correspondente: DNS spoofing/cache poisoning: resposta FALSA guardada em cache....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (DNS Attacks): DNS spoofing/cache poisoning: resposta FALSA guardada em cache.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

3) B — Implementar a solução correspondente: Typosquatting: registra domínio com typo (rn/m, 0/o) — phishing....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (DNS Attacks): Typosquatting: registra domínio com typo (rn/m, 0/o) — phishing.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) A — Implementar a solução correspondente: DNS tunneling: exfiltra dado escondido em queries DNS....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (DNS Attacks): DNS tunneling: exfiltra dado escondido em queries DNS.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: 'fake DNS response directs user to attacker server' = DNS spoofing/poisonin....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (DNS Attacks): 'fake DNS response directs user to attacker server' = DNS spoofing/poisoning.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: 'registers domain similar to legitimate one' = typosquatting....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (DNS Attacks): 'registers domain similar to legitimate one' = typosquatting.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: Cenário: 'usuário digita domínio errado e cai em site de phishing' = typosq....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (DNS Attacks): Cenário: 'usuário digita domínio errado e cai em site de phishing' = typosquatting/URL hijacking..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: DNS spoofing/cache poisoning: resposta FALSA guardada em cache....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (DNS Attacks): DNS spoofing/cache poisoning: resposta FALSA guardada em cache.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: Typosquatting: registra domínio com typo (rn/m, 0/o) — phishing....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (DNS Attacks): Typosquatting: registra domínio com typo (rn/m, 0/o) — phishing.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) B — Implementar a solução correspondente: DNS tunneling: exfiltra dado escondido em queries DNS....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (DNS Attacks): DNS tunneling: exfiltra dado escondido em queries DNS.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.